

Projet Fabricool Active Directory Lab

Module 5 - PKI Microsoft et Services Web Sécurisés

TP 13 — Gestion du cycle de vie des certificats



Auteur : ODJEKE N'bango Thiery

Filière : Licence Professionnelle Réseaux et Cybersécurité

Date : 08/07/2026

Table des matières

I.	Objectif du TP.....	2
II.	Contexte	2
III.	Architecture	2
IV.	Travaux réalisés.....	3
1.	Simulation de la compromission du site Web	3
2.	Publication et vérification sur le point de distribution (CDP)	4
3.	Validation locale sur le serveur IIS (DC-S-01)	5
4.	Procédure de validation depuis le poste client	5
5.	Analyse du comportement du cache (Serveur vs Client)	7
V.	Conclusion.....	8

I. Objectif du TP

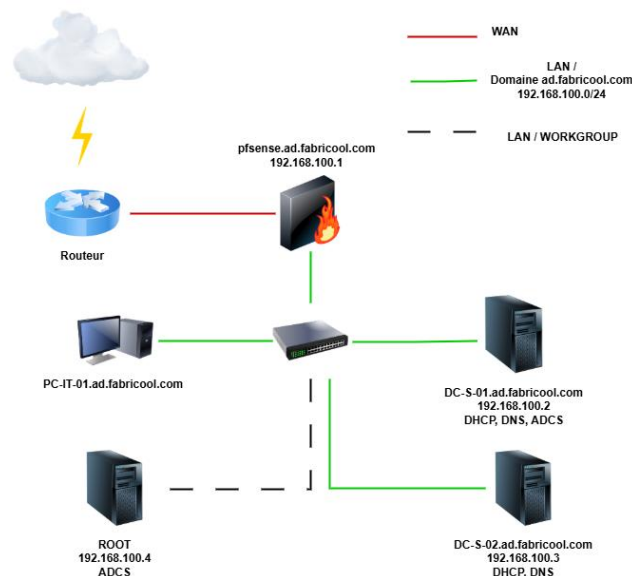
Ce TP a pour objectif de maîtriser le cycle de vie des certificats au sein de l'infrastructure PKI de l'entreprise FABRICOOL, en particulier la gestion des cas de compromission ou d'obsolescence. Il s'agit de savoir retirer la confiance accordée à un certificat compromis, de publier les listes de révocation (CRL et Delta CRL) sur le point de distribution IIS, et de vérifier que les postes clients appliquent correctement ces mises à jour.

II. Contexte

Dans la continuité des TP précédents, l'entreprise FABRICOOL dispose désormais d'une PKI hiérarchique opérationnelle et d'un portail web interne sécurisé en HTTPS. Cependant, la sécurité d'une infrastructure de certification ne repose pas uniquement sur l'émission de certificats : elle implique également la capacité à gérer leur cycle de vie et à révoquer ceux qui ne doivent plus être utilisés.

La révocation est un mécanisme essentiel pour maintenir la confiance : un certificat compromis ou expiré doit être signalé comme invalide afin d'empêcher toute utilisation frauduleuse. Les listes de révocation (CRL) et leurs versions incrémentales (Delta CRL) sont publiées sur IIS et consultées par les clients pour vérifier l'état des certificats. Ce TP illustre donc la mise en œuvre pratique de ce processus, depuis la simulation d'une compromission jusqu'à la validation côté client.

III. Architecture



Le schéma présenté inclut un pare-feu pfSense pour illustrer une architecture réseau complète. Toutefois, ce TP peut être réalisé sans pfSense.

IV. Travaux réalisés

1. Simulation de la compromission du site Web

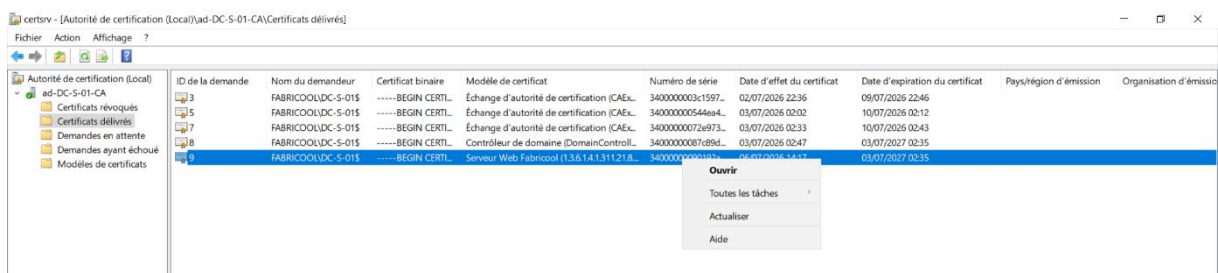
Afin de tester la capacité de l'infrastructure PKI à gérer un incident de sécurité, une simulation de compromission du certificat utilisé par IIS a été réalisée. L'objectif était d'invalider immédiatement le certificat associé au portail interne et de le déclarer comme compromis dans la base de la Subordinate CA.

* Étapes de la révocation

Depuis la console *Autorité de certification* (certsrv.msc) sur le serveur DC-S-01, le certificat délivré pour le site *web.ad.fabricool.com* a été identifié dans le dossier *Certificats délivrés*.

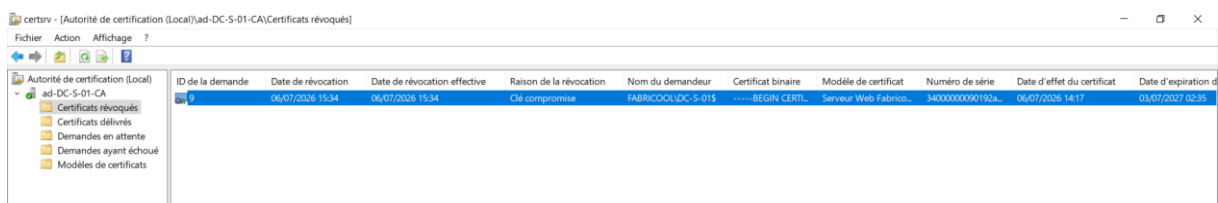
Un clic droit sur ce certificat a permis de sélectionner l'option *Toutes les tâches > Révoquer le certificat*.

Dans la liste des motifs de révocation, l'option *Compromission de clé* (Key Compromise) a été choisie, simulant une fuite ou une compromission de la clé privée associée au certificat.



* Résultat attendu

La révocation a été immédiatement appliquée : le certificat a basculé dans le dossier *Certificats révoqués*, marquant sa perte de validité. Cette opération illustre la réactivité de la PKI face à un incident de sécurité et constitue la première étape du cycle de vie de gestion des certificats compromis.

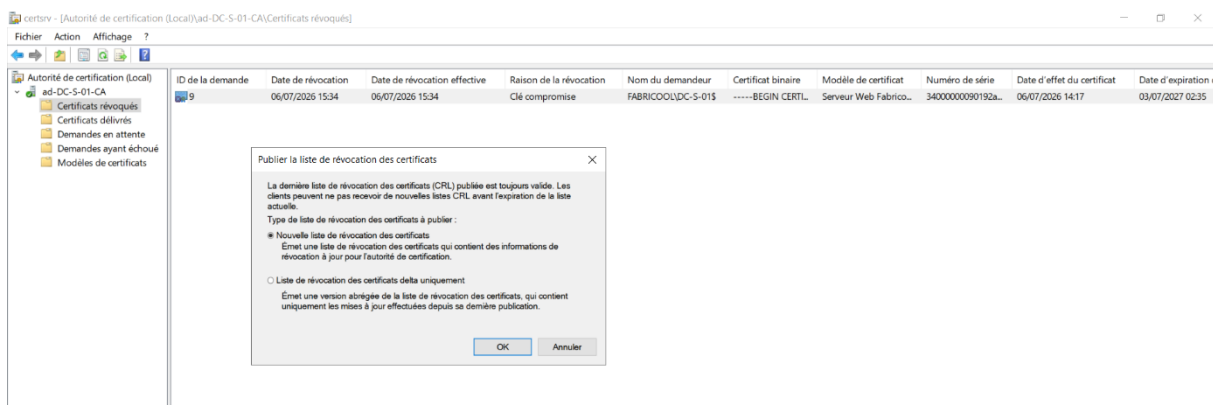


2. Publication et vérification sur le point de distribution (CDP)

Après la révocation du certificat compromis, il est nécessaire de publier les listes de révocation mises à jour afin que les clients puissent en tenir compte lors de la validation des certificats. Cette étape garantit que l'information de compromission est effectivement propagée dans l'infrastructure.

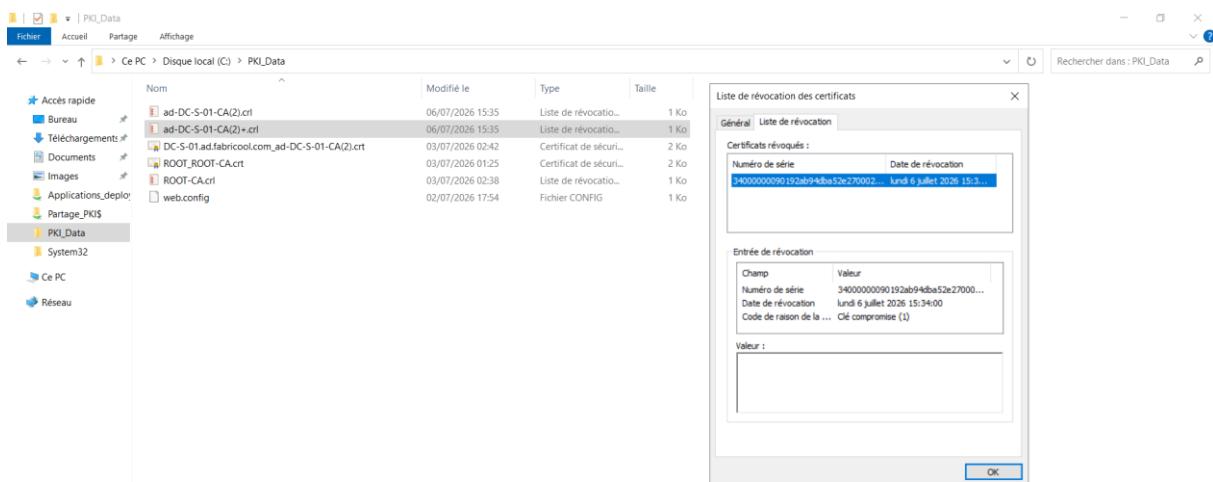
* Publication forcée des listes

Depuis la console *Autorité de certification*, un clic droit sur le dossier *Certificats révoqués* a permis de sélectionner l'option *Toutes les tâches > Publier > Nouvelle liste CRL (Base CRL)*.



* Vérification au point de distribution CDP

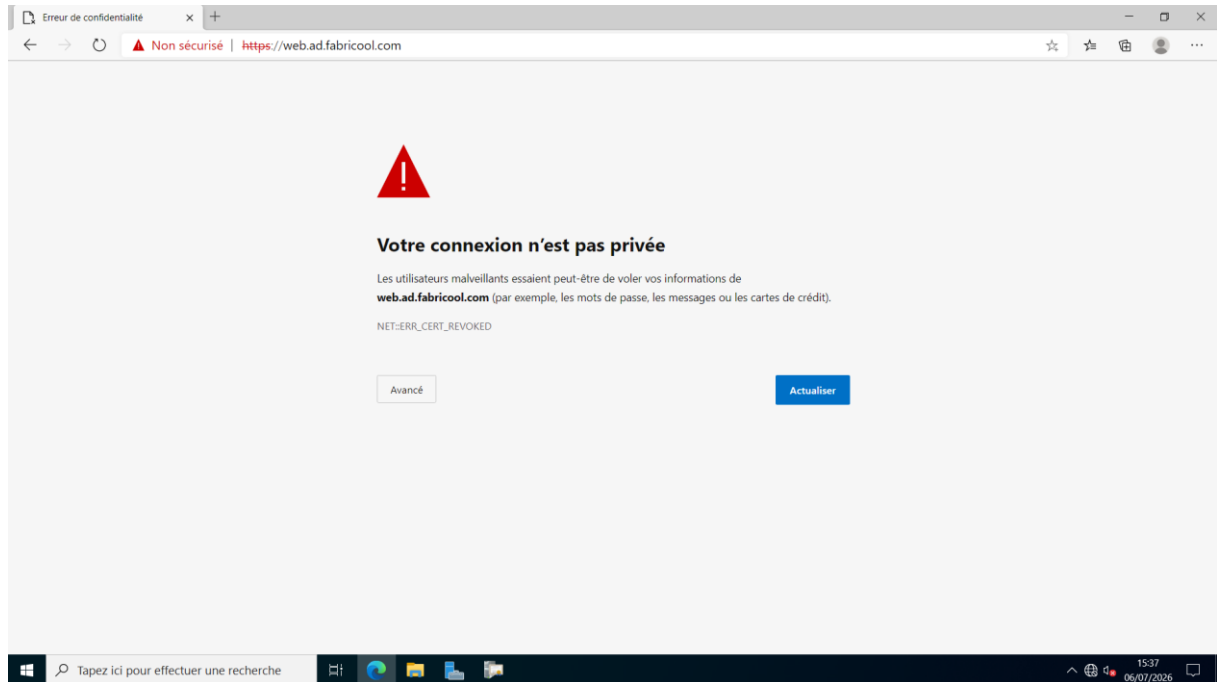
Un contrôle a ensuite été effectué dans le répertoire physique du point de distribution HTTP configuré sur IIS. Les fichiers .crl (Base et Delta) y étaient présents et portaient un horodatage correspondant à la publication forcée.



3. Validation locale sur le serveur IIS (DC-S-01)

Un premier test de validation a été effectué directement sur le serveur DC-S-01 afin de vérifier la prise en compte de la révocation.

Depuis le navigateur du serveur, l'accès à l'URL : <https://web.ad.fabricool.com> a affiché une erreur critique de type **NET::ERR_CERT_REVOKED**. Ce comportement est attendu : le serveur, n'ayant pas de contrainte de cache réseau local, interroge directement sa propre PKI et lit le nouveau statut du certificat, désormais marqué comme révoqué.

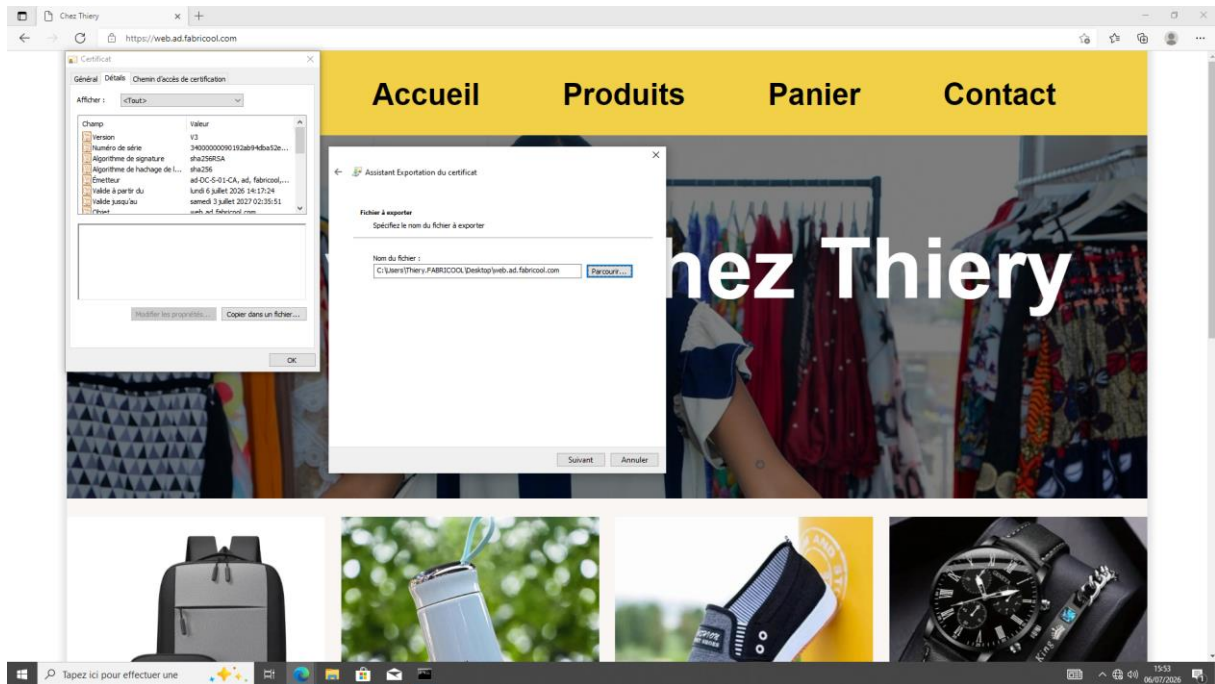


4. Procédure de validation depuis le poste client

La validation finale a été réalisée depuis un poste client du domaine afin de confirmer que la révocation est correctement propagée et interprétée par la chaîne CryptoAPI.

* Exportation du certificat compromis

Depuis le navigateur du poste client, les détails du certificat du site web.ad.fabricool.com ont été affichés puis exportés au format DER/Base64 sous le nom [web.ad.fabricool.com.cer](#).



* Vérification du statut via Certutil

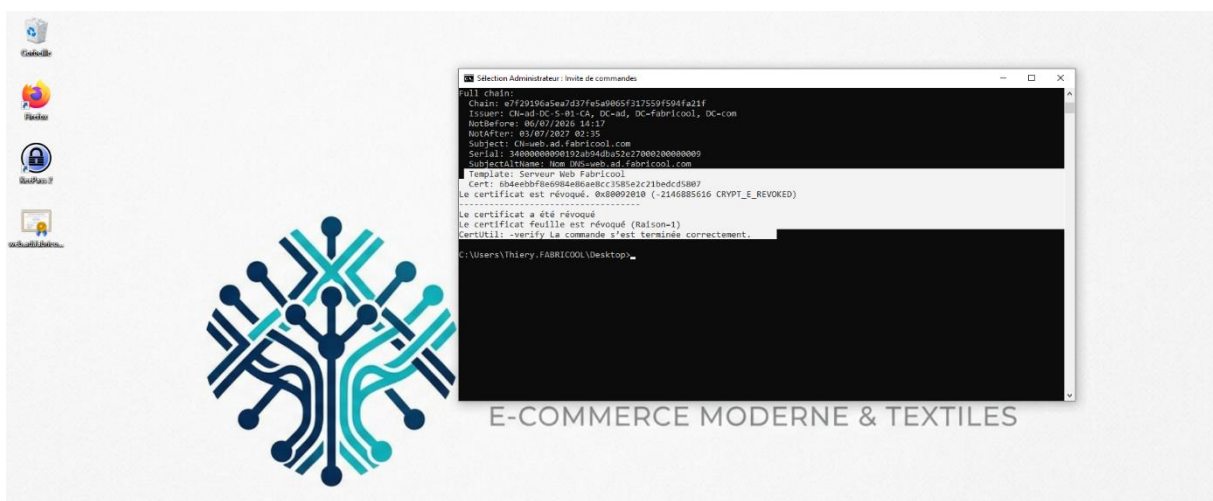
Une invite de commandes ouverte en mode administrateur a permis d'exécuter la commande suivante : ***certutil -urlfetch -verify web.ad.fabricool.com.cer.***

Cette commande force le téléchargement des CRL depuis le point de distribution HTTP et analyse la chaîne de révocation.

Le résultat attendu est explicite :

- Statut du certificat : RÉVOQUÉ (Revoked)
- Motif de la révocation : Compromission de clé (Key Compromise)

Ce diagnostic constitue le livrable principal du TP, attestant que la révocation est bien prise en compte par les clients du domaine.

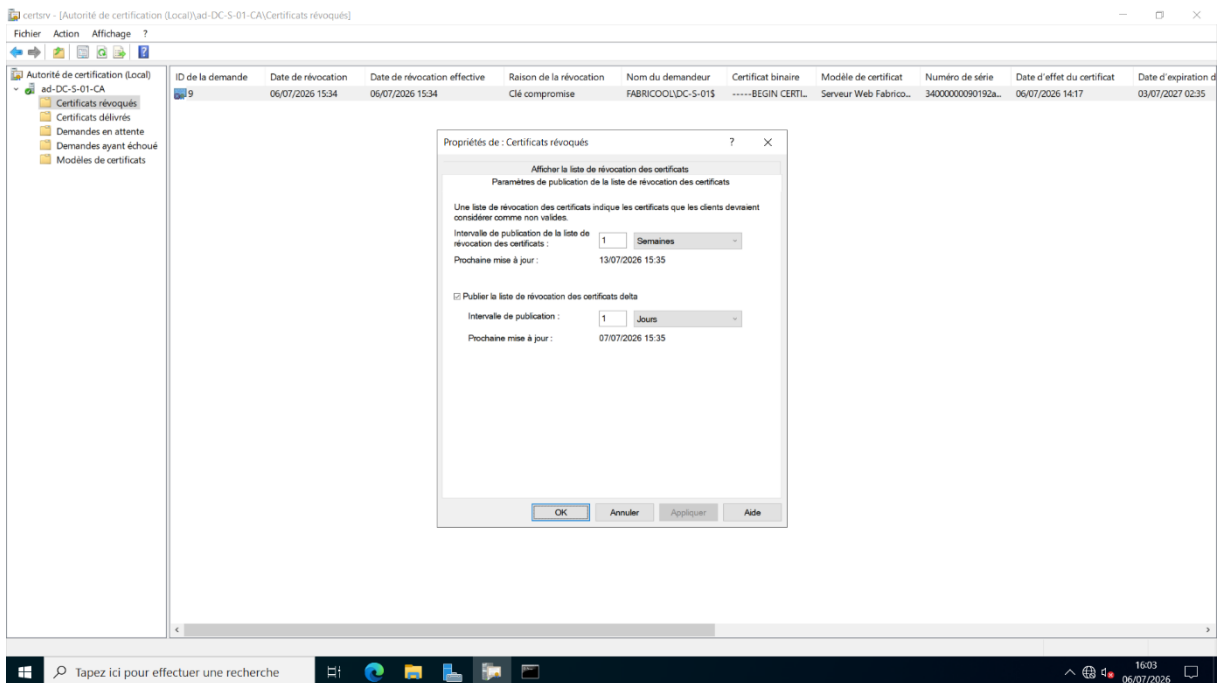


5. Analyse du comportement du cache (Serveur vs Client)

Une divergence de comportement a été observée entre le serveur et les clients existants.

- * Sur le serveur IIS, la révocation est immédiatement visible car il interroge directement la PKI sans passer par un cache intermédiaire.
- * Sur les clients ayant déjà accédé au site, la révocation peut tarder à apparaître. Ce délai est dû au mécanisme de cache CryptoAPI de Windows : les CRL et Delta CRL téléchargées sont stockées localement et utilisées jusqu'à l'expiration de leur champ NextUpdate. Tant que cette date n'est pas dépassée, le client refuse de contacter le CDP et considère le certificat comme valide.
- * En revanche, un nouveau client n'ayant jamais accédé au site télécharge immédiatement la Base CRL et la Delta CRL fraîchement publiées, et voit donc le certificat marqué comme révoqué dès sa première connexion.

Voici la configuration par défaut de la durée de validité des CRL telle qu'elle apparaît dans la console de *l'Autorité de certification*, indiquant l'intervalle prévu entre chaque publication automatique des listes de révocation.



V. Conclusion

Ce TP a démontré la capacité de l'infrastructure PKI de FABRICOOL à gérer efficacement le cycle de vie des certificats. La simulation de compromission du certificat du site *web.ad.fabricool.com*, suivie de sa révocation avec le motif *Key Compromise*, a permis d'illustrer le processus de retrait de confiance. La publication forcée des listes CRL et Delta CRL sur le point de distribution IIS a assuré la propagation immédiate de l'information de révocation. Les validations locales et côté client ont confirmé le fonctionnement du mécanisme : le serveur détecte instantanément la révocation, tandis que les clients existants peuvent conserver un statut temporairement valide en raison du cache CryptoAPI. Les nouveaux clients, eux, téléchargent directement les CRL mises à jour et constatent immédiatement l'état révoqué. Ce TP met en évidence l'importance de la gestion proactive des CRL et de la compréhension du comportement du cache côté client, garantissant une infrastructure de certification fiable et réactive face aux incidents de sécurité.